
Informe: Migracion de EduTrack a On-Premise

Proyecto: EduTrack - Plataforma de gestion educativa

Fecha: 2026-07-01

Alcance: Auditoria del servidor productivo real y plan de despliegue on-premise

Nota metodologica

Este informe se basa en una auditoria directa del servidor productivo (acceso SSH a 165.22.34.95, host edutrack-production) y en el analisis del repositorio de infraestructura como codigo. Los datos de la seccion 1 fueron verificados en el servidor real, no estimados. Ninguna credencial ni secreto se reproduce en este documento.

1. Estado real del servidor productivo (auditado)

1.1 Host y recursos

- Proveedor: 1 Droplet DigitalOcean, hostname edutrack-production.
- Sistema operativo: Ubuntu 22.04.5 LTS, kernel 5.15.0-179.
- CPU / RAM: 2 vCPU / 3.8 GB RAM.
- Disco: 78 GB, 53 por ciento usado (37 GB libres).
- Swap: 4 GB, con 796 MB en uso -> hay presion de memoria: el host esta al limite de RAM.
- Uptime: 31 dias. Docker 29.1.3 + Compose v2.29.7.

1.2 Todo corre en un unico host (20 contenedores)

A diferencia de lo que sugiere la documentacion (Moodle en servidor aparte), en la practica TODO esta colocado en el mismo Droplet: nucleo EduTrack, Keycloak, Moodle y el stack completo de monitoreo (20 contenedores).

- Nucleo: web (Next.js), auth (Express, healthy), keycloak 26.3.3, keycloak-db (Postgres 16), pg

(Postgres 16), redis 7.

- LMS: moodle 5.0.2 + mariadb 11.8 (imagenes bitnamilegacy).
- Borde: reverse-proxy nginx 1.27 (80/443).
- Monitoreo: grafana, prometheus, loki, alloy, cadvisor, blackbox / node / nginx / postgres exporters, y un proxy de remote-write via Tailscale.

Consumo de memoria observado: Keycloak 517 MB (el mas pesado), moodle 346 MB, mariadb 170 MB, auth 213 MB. El stack de monitoreo suma cerca de 470 MB. Sobre 3.8 GB totales, esto explica el uso de swap.

1.3 Volumen de datos (muy chico)

- Base asistencias: 38 MB. Base keycloak: 13 MB.
- Filas: Attendance 6459, BiometricPunch 6303, MoodleEnrolmentMap 1838, Student 103.
- Peso total de volúmenes Docker: cerca de 2.3 GB, de los cuales Prometheus (970 MB) es el mayor; los datos de negocio reales son unos pocos cientos de MB.

Conclusion: es una institucion de escala chica. El dimensionamiento on-premise NO necesita ser grande; el cuello de botella actual es RAM, no disco ni CPU.

1.4 SaaS realmente activos (verificado en .env)

- Moodle (sync ACTIVO, token de web service presente).
- OpenAI (asistente NL a SQL ACTIVO).
- Sentry backend y frontend (ACTIVO).
- LogRocket (ACTIVO).
- Didit prueba de vida (ACTIVO).
- Turnstile CAPTCHA (ACTIVO).
- Email por SMTP (ACTIVO; el modo API de SendGrid esta vacio, se usa SMTP directo).
- Web push VAPID (ACTIVO).
- Google OAuth: VACIO -> el login social de Google NO se usa; la identidad es solo Keycloak.

1.5 Borde y TLS

- reverse-proxy nginx sirve: edutrack-uy.com, www, api.edutrack-uy.com, auth.edutrack-uy.com, moodle.edutrack-uy.com (todos los subdominios en un solo proxy).
- TLS: certificado Origin de Cloudflare (cert.pem / key.pem) instalado en /etc/ssl/cloudflare desde el 22 de marzo. El SSL publico lo termina Cloudflare.

1.6 Backups

- cron diario 03:00: script backup_pg_offsite.sh que replica a un segundo VPS (138.197.35.2) por SSH. Retencion 30 dias remoto / 3 dias local.

- Moodle: cron cada minuto (cron.php).
 - No hay timers systemd de backup adicionales; el respaldo depende del cron de root.
-

2. Hallazgos de seguridad detectados (accion recomendada antes o durante la migracion)

Estos puntos ya son deuda en el entorno cloud y NO deben arrastrarse al on-premise:

1. Firewall de host inactivo: ufw esta inactive. La proteccion depende enteramente de Cloudflare y del firewall de red de DigitalOcean. On-premise, sin esa capa cloud, esto es critico: hay que activar firewall de host y perimetral desde el día uno.
 2. Puertos directos expuestos: web (3000), auth (4000) y keycloak (8089) estan publicados en 0.0.0.0, ademas de 80/443. El override docker-compose.close-ports.prod.yml existe en el repo pero NO esta aplicado en produccion. Cualquiera con la IP puede saltarse el reverse-proxy.
 3. Keycloak en modo start-dev: corre en modo desarrollo, no productivo (start --optimized). Sin endurecer hostname/SSL a nivel del propio Keycloak.
 4. Reboot pendiente: el kernel en ejecucion es 5.15.0-179 pero hay 5.15.0-185 instalado. Faltan parches de seguridad por reinicio.
 5. Secrets por defecto: revisar que JWT_SECRET, KEYCLOAK_CLIENT_SECRET, KEYCLOAK_ADMIN_PASSWORD y KEYCLOAK_DB_PASSWORD no conserven los valores de ejemplo del repo (change-me, admin, edutrack-web-secret-change-me).
-

3. Arquitectura on-premise objetivo

Esquema de referencia:

- Internet (opcional, solo si hay acceso externo).
- Firewall / Router perimetral (pfSense u OPNsense): reemplaza el firewall de red de DigitalOcean.
- Host(s) Docker de la institucion:
 - nginx reverse-proxy (80/443) con TLS propio, unica entrada publica.
 - web (Next.js :3000), auth / API (Express :4000) conectado al reloj biometrico ZKTeco F22, keycloak (:8080) en modo productivo.
 - pg (Postgres 16), redis, keycloak-db.
 - moodle + mariadb.
 - Servicios de reemplazo SaaS: Postfix (SMTP), GlitchTip (Sentry), Ollama (LLM).
 - Monitoreo: Grafana / Prometheus / Loki / Alloy (ya self-hosted).
- LAN: reloj biometrico ZKTeco F22 y NAS de backups.

Regla de oro on-premise: todo lo que hoy sale a un dominio de un tercero debe resolverse dentro de

la red de la institucion.

4. Hardware y sistema base (ajustado a la realidad medida)

Dado que el volumen de datos real es de pocos cientos de MB y el cuello de botella actual es la RAM (3.8 GB con swap en uso), el dimensionamiento on-premise es modesto:

- Recomendado, single host: 4 vCPU / 16 GB RAM / 2 x 480 GB SSD en RAID 1. Holgado para los 20 contenedores actuales mas margen (hoy sufren con 3.8 GB).
- Si se agrega el asistente NL a SQL con LLM local: sumar una segunda maquina con GPU (por ejemplo RTX 4060 16 GB) para Ollama, o dejar esa funcion apagada. Un LLM no cabe en el host principal.
- Alta disponibilidad (opcional pero recomendable): un segundo host identico para replica de Postgres y failover manual.

Sistema operativo: mantener Ubuntu Server 22.04/24.04 LTS o Debian 12. Docker Engine + compose-plugin. unattended-upgrades activo (ya presente via apt-daily-upgrade.timer). UPS obligatorio.

5. Red, DNS y TLS (reemplazar Cloudflare)

Cloudflare hace hoy tres funciones que desaparecen on-premise: DNS publico, terminacion TLS y CAPTCHA (Turnstile).

5.1 DNS interno

Montar DNS local (Pi-hole, dnsmasq o BIND / el DNS del Active Directory) que resuelva los mismos nombres que ya usa el nginx:

- edutrack.institucion.local y api / auth / moodle equivalentes -> IP del reverse-proxy.

Estos hostnames van en PUBLIC_HOST, KEYCLOAK_HOSTNAME, KEYCLOAK_ISSUER_URL, NEXT_PUBLIC_API_URL, CORS_ORIGINS, MOODLE_BASE_URL, MOODLE_PUBLIC_URL.

5.2 TLS propio

- CA interna (recomendado en LAN cerrada): CA propia, certificado wildcard *.institucion.local, y distribucion del CA root a los equipos por GPO o MDM. El certificado se monta en el mismo path que hoy usa el reverse-proxy (/etc/ssl/cloudflare), reemplazando el Origin Cert de Cloudflare por el propio.
- Let's Encrypt (si hay dominio publico y salida a internet): Caddy o nginx + certbot con desafio

DNS-01.

5.3 Endurecer Keycloak (corregir hallazgo 2.3)

Pasar de start-dev a modo productivo:

- command: start --optimized --import-realm
- KC_HOSTNAME apuntando al hostname interno con https, KC_PROXY_HEADERS xforwarded, KC_HTTP_ENABLED true (el TLS lo termina nginx).
- Rotar todos los secrets de Keycloak y de la app.

5.4 Firewall (corregir hallazgos 2.1 y 2.2)

- Activar ufw en el host: permitir solo 22 (idealmente restringido a la LAN de gestion), 80 y 443.
- Aplicar el override docker-compose.close-ports.prod.yml para que web, auth, keycloak y moodle dejen de publicar puertos directos y queden solo en la red Docker interna.
- Firewall perimetral (pfSense / OPNsense) reemplazando el firewall de red de DigitalOcean.

6. Reemplazo de cada dependencia SaaS (segun lo realmente activo)

- Email SMTP (ACTIVO) -> Postfix local o relay del correo institucional. Setear SMTP_HOST / PORT / USER / PASS al servidor interno. Preferir el relay institucional ya reputado para evitar spam.
- Sentry backend y frontend (ACTIVO) -> GlitchTip self-hosted (compatible con el SDK de Sentry, liviano). Solo se cambian SENTRY_DSN y NEXT_PUBLIC_SENTRY_DSN. Cero cambios de codigo.
- LogRocket (ACTIVO) -> OpenReplay self-hosted, o apagarlo vaciando NEXT_PUBLIC_LOGROCKET_APP_ID (el session replay no es esencial).
- OpenAI, asistente NL a SQL (ACTIVO) -> Ollama o vLLM local. Apuntar OPENAI_API_KEY y OPENAI_SQL_MODEL al endpoint local. Requiere GPU para calidad aceptable; sin GPU, apagar la funcion (el endpoint degrada a 503 de forma limpia). Importante: no degradar la calidad de las respuestas por ahorrar; si no hay GPU, es preferible desactivarla.
- Turnstile CAPTCHA (ACTIVO) -> en LAN cerrada el CAPTCHA sobra; vaciar TURNSTILE_SECRET y NEXT_PUBLIC_TURNSTILE_SITE_KEY, o sustituir por un anti-bot propio si hay exposicion a internet.
- Didit prueba de vida (ACTIVO) -> funcion opcional; evaluar alternativa on-premise o desactivar vaciando las variables DIDIT.
- Web push VAPID (ACTIVO) -> ya es self-contained (las claves son propias); no depende de un SaaS, se mantiene igual.
- Google OAuth (NO se usa) -> nada que hacer; la identidad ya pasa 100 por ciento por Keycloak. Recomendado: federar Keycloak contra el AD / LDAP institucional para SSO con las cuentas

existentes.

- Tailscale (acceso remoto a monitoreo) -> WireGuard propio, o restringir el monitoreo a la LAN.

Punto fuerte del diseño: cada integración sigue el patrón "si falta la variable, se desactiva". Apagar o redirigir cada SaaS es cuestión de .env, sin tocar código.

7. Moodle on-premise (corrección importante)

En producción Moodle NO está en un servidor aparte: corre colocado en el mismo Droplet (contenedores edutrack-moodle-1 y edutrack-moodle-db-1, imágenes bitnamilegacy). On-premise:

- Mantenerlo en la misma red Docker (edutrack_moodle-net) para que auth lo alcance por nombre.
 - Federar el login de Moodle contra el mismo Keycloak (script moodle-config-keycloak-sso.sh) para SSO unificado.
 - Atención: las imágenes pasaron a bitnamilegacy (sin soporte activo). Para on-premise de largo plazo, planear el pin de versión y un mirror interno de imágenes, o migrar a una imagen de Moodle mantenida.
-

8. Biometría ZKTeco F22

Ya es naturalmente on-premise: el reloj vive en la LAN y habla ADMS / iClock contra el endpoint de auth. On-premise se simplifica: el reloj apunta directo a <https://edutrack.institucion.local> en la LAN, sin pasar por Cloudflare ni salir a internet. Configurar BIOMETRIC_ADMS_SERIAL con el número de serie real. Los datos actuales (6303 marcas registradas) confirman que el flujo está operativo.

9. Backups (adaptar el offsite)

Hoy el backup diario 03:00 replica a un segundo VPS (138.197.35.2) vía SSH, con retención 30 días remoto / 3 local. On-premise hay que reemplazar ese destino cloud por infraestructura propia y aplicar la regla 3-2-1:

- Destino primario: NAS interno (Synology / TrueNAS).
- Copia offsite: disco cifrado rotativo fuera del edificio (o bucket cifrado si la política lo permite).
- Respaldo ambas bases (asistencias y keycloak: perder keycloak es perder todas las identidades) y los volúmenes moodle_moodledata, moodle_mariadb_data, redisdata (sesiones).
- Probar el restore periódicamente (existe restore_pg_custom_dump_cloud.sh como base). Un backup sin restore probado no existe.
- El esquema se aplica con db push --accept-data-loss al arrancar: un backup previo a cada deploy

es obligatorio.

10. CI/CD y actualizaciones sin internet

Hoy el deploy es push a main -> GitHub Actions -> SSH al Droplet. On-premise, si la red es cerrada:

- Registro Docker interno (Harbor o registry:2) para publicar las imagenes web y auth ya construidas.
 - Runner self-hosted de GitHub Actions o GitLab CI dentro de la red, o build manual con push al registro interno.
 - Mirror de imagenes base (postgres, keycloak, nginx, redis, moodle, exporters) en el registro interno: elimina la dependencia de Docker Hub / quay / gcr y sus rate limits.
 - Los scripts existentes (deploy-sync-repo.sh, deploy-wait-healthy.sh, deploy-compose-functions.sh) se adaptan con cambios minimos.
-

11. Monitoreo y observabilidad

El stack Grafana + Prometheus + Loki + Alloy + exporters ya es 100 por ciento self-hosted y esta operativo (Prometheus retiene 15 dias, cerca de 970 MB). On-premise:

- Bindear Grafana solo a la LAN (ya escucha en 127.0.0.1:3001; exponerlo por el reverse-proxy con auth o por VPN).
 - Reemplazar el proxy de remote-write via Tailscale por WireGuard, o dejar todo el monitoreo dentro de la LAN.
 - Configurar alertas (Alertmanager -> email via Postfix, o mensajeria interna). Alerta clave: memoria del host, dado el estrechez de RAM observada.
-

12. Plan de migracion (orden recomendado)

1. Preparar infraestructura base: host(s) con mas RAM que el actual, SO, Docker, DNS interno, CA / TLS, firewall perimetral y de host.
2. Corregir de entrada los hallazgos de seguridad: ufw activo, close-ports aplicado, Keycloak en modo start, kernel al dia, secrets rotados.
3. Levantar los servicios de reemplazo: Postfix, GlitchTip, registro interno (y Ollama si aplica).
4. Desplegar el core con el .env on-premise (hostnames internos, secrets nuevos, SaaS redirigidos o apagados).
5. Migrar datos: pg_dump de asistencias y keycloak (juntos son 51 MB) y restore en el on-premise; copiar moodledata y mariadb.

6. Validar con los scripts existentes: `validate-production-routes.sh`, `validate-reverse-proxy-env.sh`, `verify-auth-keycloak-network.sh`.
 7. Enrolar el reloj F22 contra el endpoint interno.
 8. Cutover: apuntar DNS y clientes al nuevo entorno; monitorear 48 a 72 horas antes de dar de baja el cloud.
-

13. Riesgos y decisiones a tomar

- RAM: el entorno actual ya sufre con 3.8 GB (swap en uso). El host on-premise debe partir con mas memoria, no igual.
 - Asistente NL a SQL: sin GPU local la calidad NL a SQL cae; decidir entre GPU dedicada o apagar la funcion.
 - Correo saliente: un Postfix propio puede caer en spam; preferir el relay del correo institucional.
 - Alta disponibilidad: hoy es single-host (punto unico de falla) con 20 contenedores juntos. Un on-premise serio pide al menos replica de Postgres y un segundo host.
 - Moodle bitnamilegacy: imagenes sin soporte activo; planificar estrategia de actualizacion.
 - Parches: on-premise, los reinicios por kernel y las actualizaciones de Keycloak / Postgres / Moodle son responsabilidad propia; el reboot pendiente detectado es un ejemplo a no repetir.
-

Resumen ejecutivo

La auditoria del servidor real muestra un despliegue chico pero denso: 20 contenedores (nucleo + Moodle + monitoreo completo) sobre un unico Droplet de 2 vCPU y 3.8 GB de RAM que ya opera con presion de memoria, aunque el volumen de datos de negocio es minimo (bases de 38 y 13 MB). El nucleo ya es Docker Compose puro con reverse-proxy nginx y monitoreo self-hosted, asi que la portabilidad a on-premise esta practicamente resuelta a nivel aplicacion. El trabajo real es doble: primero, construir el entorno que hoy aporta el cloud (DNS y TLS propios en lugar de Cloudflare, firewall perimetral y de host en lugar del firewall de DigitalOcean, backup a NAS interno en lugar del VPS secundario); segundo, sustituir los SaaS realmente activos (Sentry, LogRocket, OpenAI, Turnstile, Didit y el SMTP) por equivalentes locales o apagandolos, algo que el diseno permite via `.env` sin tocar codigo. En el camino conviene corregir cuatro deudas ya presentes en cloud que serian graves sin la red de seguridad del proveedor: firewall de host inactivo, puertos de aplicacion expuestos directamente, Keycloak en modo desarrollo y parches de kernel pendientes. Las dos decisiones de fondo son el LLM del asistente (GPU local o desactivarlo) y la estrategia de backups y alta disponibilidad, que en on-premise pasan a ser enteramente responsabilidad de la institucion.